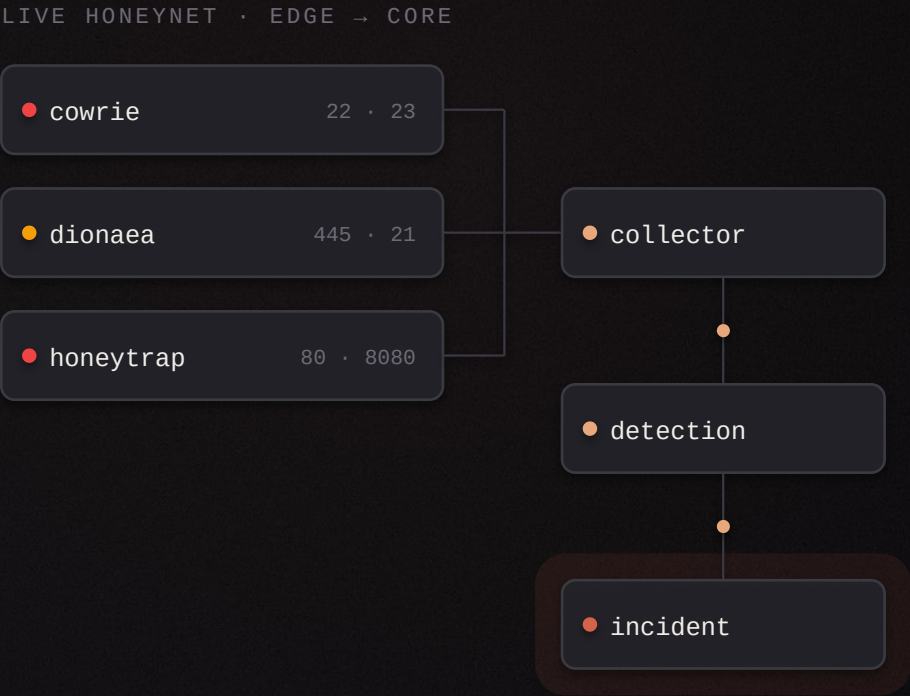
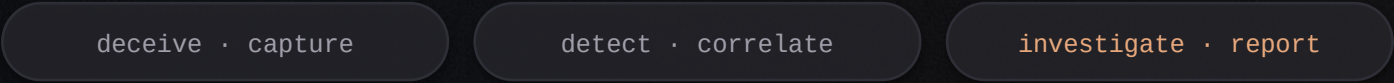


A honeynet that investigates itself.

Honeypot-driven threat intelligence, detection and IOC enrichment — the whole pipeline on one laptop.



INC-000142 · HIGH · T1110 → T1059
brute force → shell · risk 86 · explained

Security operations you cannot practise



Nobody sees the attacks that matter

Textbook labs replay canned PCAPs. Real adversary behaviour — the scanning, the guessing, the first command after a login — never reaches the student.



Alerts arrive without a story

A tool says HIGH and stops there. Why it fired, what else it touched, and which stage of the attack it belongs to are left to the analyst.



A SOC costs more than a lab has

SIEM licensing, sandbox subscriptions and threat-intel feeds put an end-to-end detection pipeline out of reach of a college project.



Compliance evidence is collected by hand

Control evidence is screenshotted into spreadsheets once a year, so it is stale the day it is filed and traceable to nothing.

Four symptoms, one cause: **there is nowhere safe to watch a real attack unfold.**

What this project set out to build

A self-contained security operations platform that produces its own evidence.

PROBLEM STATEMENT

Design and implement a honeynet-driven platform that captures real attacker telemetry, converts it into explainable detections and incidents, and produces audit-grade evidence — without cloud services or paid tooling.

SCOPE BOUNDARY — DECLARED UP FRONT

- in scope** deception, detection, correlation, investigation, reporting, GRC readiness
- out of scope** named-APT attribution, offensive tooling, production-scale throughput
- honesty rule** an unconfigured capability reports “not configured” — it never simulates output

- 01 Capture** Run real honeypot sensors on an isolated network and ingest everything they observe, losslessly.
- 02 Normalise** Reduce three different sensor formats to one sensor-agnostic event schema, deduplicated by content.
- 03 Detect** Evaluate declarative rules over that stream and raise detections that state their own reasoning.
- 04 Correlate** Group related detections into incidents with an explainable risk score and a reconstructed timeline.
- 05 Enrich** Extract and enrich IOCs, map activity to MITRE ATT&CK, and profile attacker behaviour from measured signals.
- 06 Prove** Preserve evidence under chain of custody and generate reports whose every number traces to a query.

Six objectives, one test of success: **can a stranger verify every claim the platform makes?**

Where the literature stops

22 papers surveyed across deception, detection engineering and SOC automation.

DECEPTION RESEARCH

- High-interaction honeypots capture rich sessions
- Deployment and containment patterns are well studied
- Datasets are published as raw logs

Stops at capture. The analytic layer is left to the reader.

DETECTION ENGINEERING

- Sigma gave rules a portable grammar
- ATT&CK gave findings a shared vocabulary
- Coverage is measured per rule set

Assumes a SIEM already holds the data. The pipeline is out of frame.

SOC AUTOMATION

- Correlation and triage reduce analyst load
- ML is applied to alert prioritisation
- Explainability is a stated open problem

Evaluated on enterprise telemetry nobody outside the enterprise can obtain.

THE GAP THIS PROJECT FILLS

No open, single-machine system carries one event from a live honeypot all the way to a graded incident, an ATT&CK mapping, a chain-of-custody record and a compliance control — with the reasoning preserved at every hop.

THE IDEA

Let the attackers **write the dataset.**

Stand up real sensors. Let them be attacked. Turn what they see into detections, incidents and evidence — automatically.

capture

correlate

prove

One pipeline, eight capabilities



Deception

Three attack-facing sensors on an isolated network capture SSH, SMB, FTP, MSSQL and HTTP intrusions.



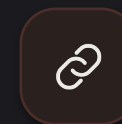
Ingestion

A cursor-based collector tails sensor output and normalises it into one schema, deduplicated by hash.



Detection

Declarative YAML rules evaluate the stream and emit detections carrying reason, confidence and ATT&CK.



Correlation

Related detections roll up into incidents with an explainable risk breakdown and a reconstructed timeline.



Behaviour

A temporal interaction graph with real centrality classifies how the attacker worked — never who they were.



Analysis

Binary, APK and URL engines with YARA, ClamAV, secret detection and an egress-free sandbox shell.



Governance

49 SOC 2 criteria scored from 25 collectors that query the running system, plus an automated risk register.



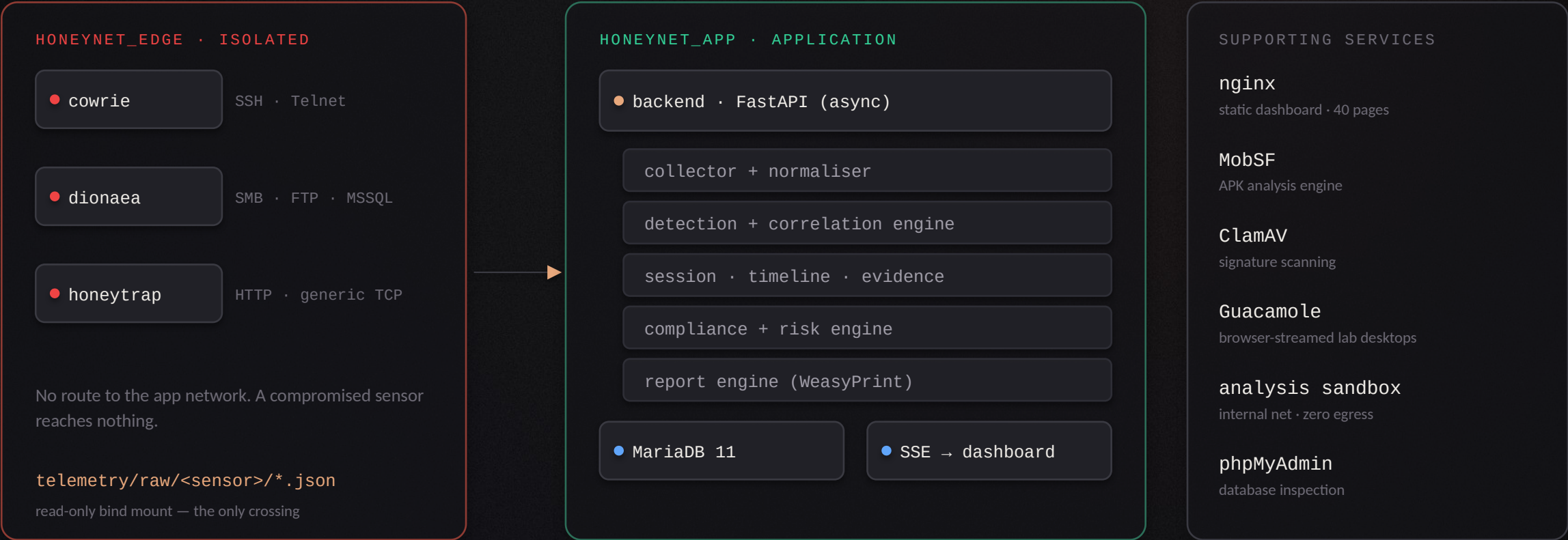
Reporting

Eight report types rendered from live data, each stamped with provenance and a document hash.

Every capability reads the same normalised event stream — **one graph underneath all eight.**

Two networks that never bridge

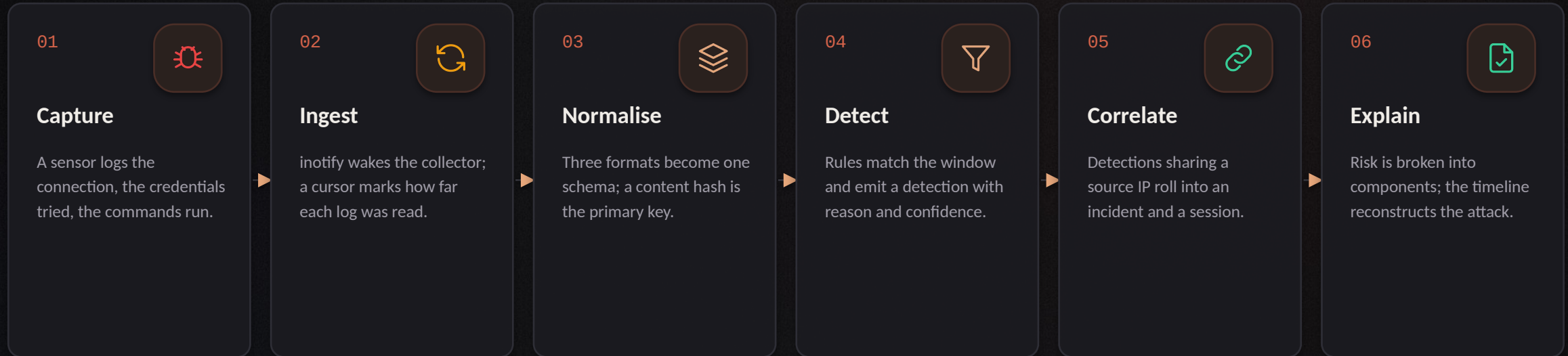
Containment is architectural, not a configuration flag.



Twelve containers by default, one `docker compose up` — and the edge can never reach the core.

From a sensor write to a graded incident

Six hops. Every one of them records why it did what it did.



THE PROPERTY THAT MAKES IT SAFE TO REPLAY

Cursors commit in the same transaction as the events. If the process dies mid-cycle the transaction rolls back, the same bytes are re-read, and the content-hash primary key absorbs the repeat. Committing cursors separately would risk the opposite failure — advancing past events that were never stored.

Idempotent end to end: **re-processing the same events creates nothing new.**

Three sensors, three attack surfaces

● cowrie

SSH · Telnet

listening on 22 · 23

- Full shell emulation — the attacker gets a prompt
- Every credential pair and every command recorded
- Downloads captured as files, not just URLs

● dionaea

SMB · FTP · MSSQL

listening on 445 · 21 · 1433

- Malware-collecting protocol emulation
- Captures dropped binaries for analysis
- Catches worm and scanner traffic SSH never sees

● honeytrap

HTTP · generic TCP

listening on 80 · 8080

- Low-interaction catch-all for unclaimed ports
- Web exploitation and path-traversal attempts
- Widens coverage without widening the attack surface

CONTAINMENT

The sensors are meant to be attacked — that is the point. They sit on a Docker network with no route to the application network, and their logs cross into the platform as a read-only mount.

REPRODUCIBILITY

A replay script regenerates the same telemetry offline, so detection work and the review demonstration never depend on somebody choosing to attack the honeypot that afternoon.

The collector, and why it cannot lose an event

Kernel-driven, not polled

inotify wakes the collector the moment a sensor appends. Interval polling is only the fallback where inotify is unavailable.

Cursors, not timestamps

Each sensor log carries a byte cursor. Restarting re-reads from the cursor, never from the beginning and never from “now”.

Content hash as primary key

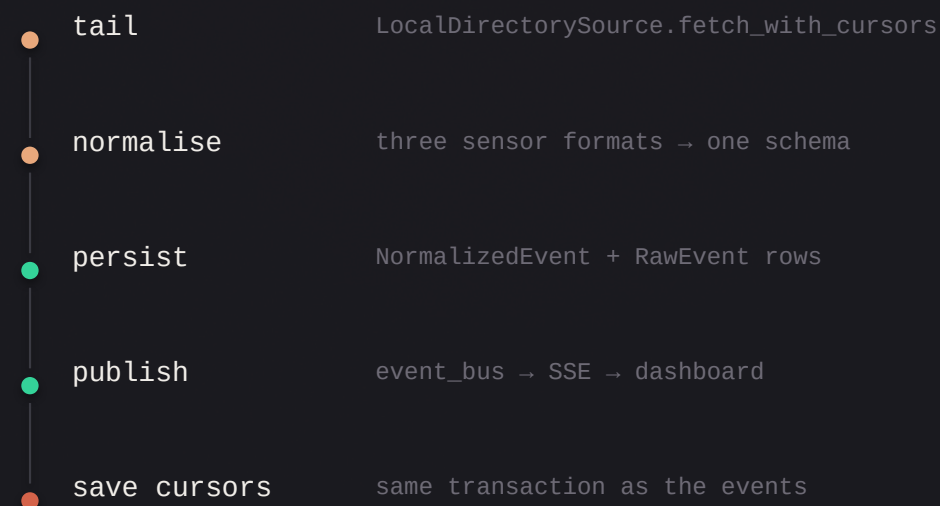
The normalised event's hash is its identity, so a re-read of the same bytes silently collapses instead of duplicating.

Latency is measured, not assumed

Every published batch records sensor-write-to-publication time, surfaced at

~~Losing telemetry silently is the failure mode this design is built against.~~

ONE COLLECTOR CYCLE



The S3 path used in AWS mode shares this same normalisation module — one schema, two sources, no divergence between local and cloud deployments.

Rules that carry their own reasoning

detections/st-auth-001.yml

```
id: st-auth-001
name: SSH / Telnet brute force
severity: HIGH
confidence: 0.8
attack:
  technique: T1110
  tactic: Credential Access
type: threshold
selection:
  authentication_result: FAILURE
timeframe: 10m
group_by: source_ip
threshold: 5
```

A detection nobody can explain is an alert, not a finding.

Declarative, versioned, mounted read-only

Rules are YAML files under backend/detections/ — reviewable in a diff, reloadable without a code change.

Threshold and sequence matching

Count-within-a-window rules and ordered-behaviour rules, both grouped by an arbitrary field.

Every detection states its reason

Rules carry the matched events, a human-readable reason, a confidence value, severity and the ATT&CK technique.

SHIPPED RULE SET					
st-auth-001	brute force	T1110	st-cred-002	success after brute force	T1078
st-exec-003	post-exploitation command	T1059	st-exec-004	stager download	T1105
st-exec-005	suspicious PowerShell	T1059.001	st-recon-006	port / service scan	T1046

From scattered detections to one graded incident

Severity is computed, not asserted — and the arithmetic is stored alongside it.

INC-000142

HIGH

source 185.***.***.42 · 6 detections · 4 techniques

RISK BREAKDOWN — STORED WITH THE INCIDENT

severity_component		72	max severity rank × 18
detection_component		24	6 detections × 6, capped at 24
technique_component		20	4 techniques × 5, capped at 20
event_component		11.4	max event risk × 0.15, capped at 15
session_component		8.2	session events × 0.2, capped at 10
malware_component		0	no linked sample analysis
total		86	capped at 100

- Grouped by source, bounded by time**
Activity from one source folds into an open incident for six hours; beyond that a new incident opens.
- Attack reconstruction timeline**
Detections, raw events and analyst actions merge into one ordered narrative of the intrusion.
- Linked IOCs and techniques**
URLs, domains and file hashes extracted from the matched events, deduplicated by type and value.
- Analyst audit trail**
Every status change, note and evidence attachment is recorded against the incident, attributed and timestamped.

The correlation cycle runs roughly every 20 seconds against a two-hour lookback window.

Evidence you could hand to somebody else

CHAIN OF CUSTODY, PER ITEM

- **content_hash** SHA-256 of the evidence blob, computed on ingest
- **immutable** true by default — items are appended, never edited
- **collected_by** the authenticated analyst who attached it
- **collected_at** UTC timestamp written at attachment
- **incident_id** the incident the item belongs to
- **access** authenticated endpoint only — never a static path
An analyst can re-hash a stored item months later and prove it is the artefact that was collected — or prove that it is not.

WHERE DANGEROUS ARTEFACTS LIVE

- **backend/quarantine/** captured malware samples
- **backend/evidence/** incident evidence blobs
- Never served by nginx and never committed to the repository.
- Malware samples leave only through GET /evidence/{id}/sample, behind authentication.
- The isolation is covered by an automated test — test_malware_isolation.py.

TIMELINE RECONSTRUCTION

timeline_builder merges normalised events, detections, session commands and analyst activity into a single ordered account of the intrusion — the artefact an examiner actually reads, and the spine of the DFIR report.

How the attacker worked — never who they were

Temporal interaction graph

Sessions, source addresses, commands and observed indicators become nodes and edges over a rolling 30-day window.

Real graph mathematics

Centrality and connected components are computed with networkx — not estimated, and not hand-waved in the UI.

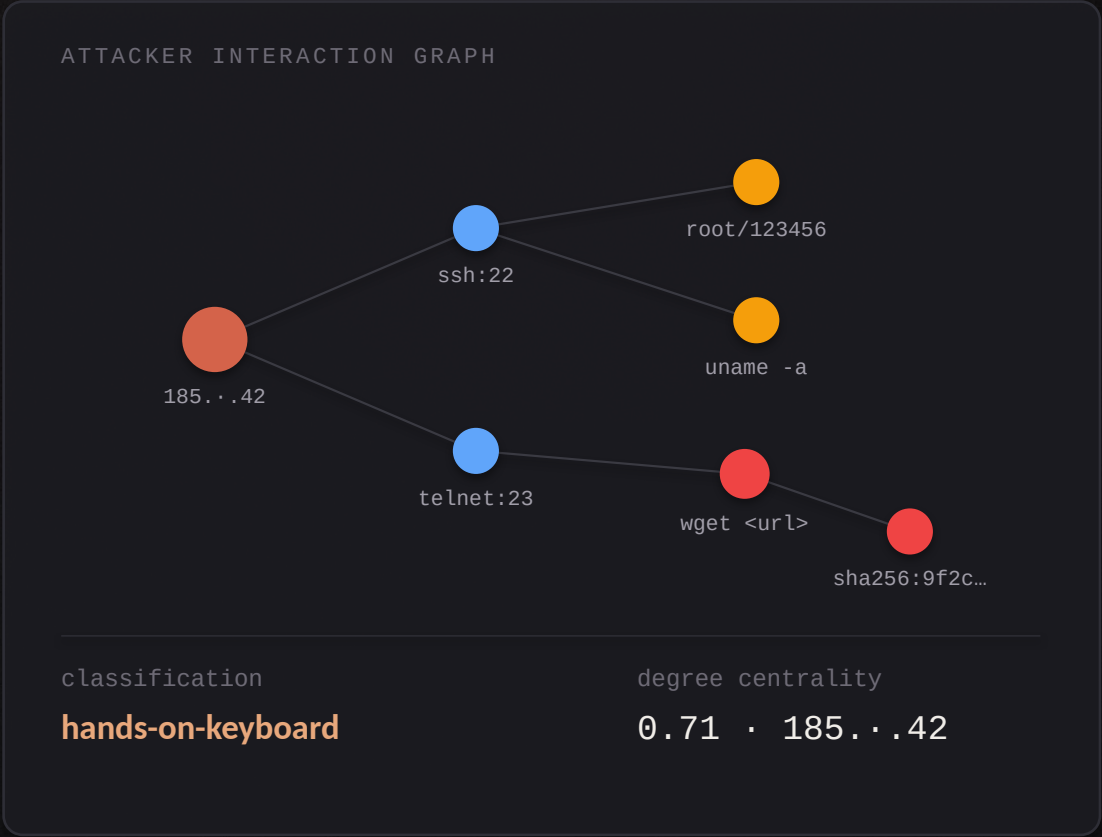
Style, not identity

Activity is classed as automated scanner, credential-stuffing bot or hands-on-keyboard from measured signals: timing, entropy, command variety.

Deliberately no attribution

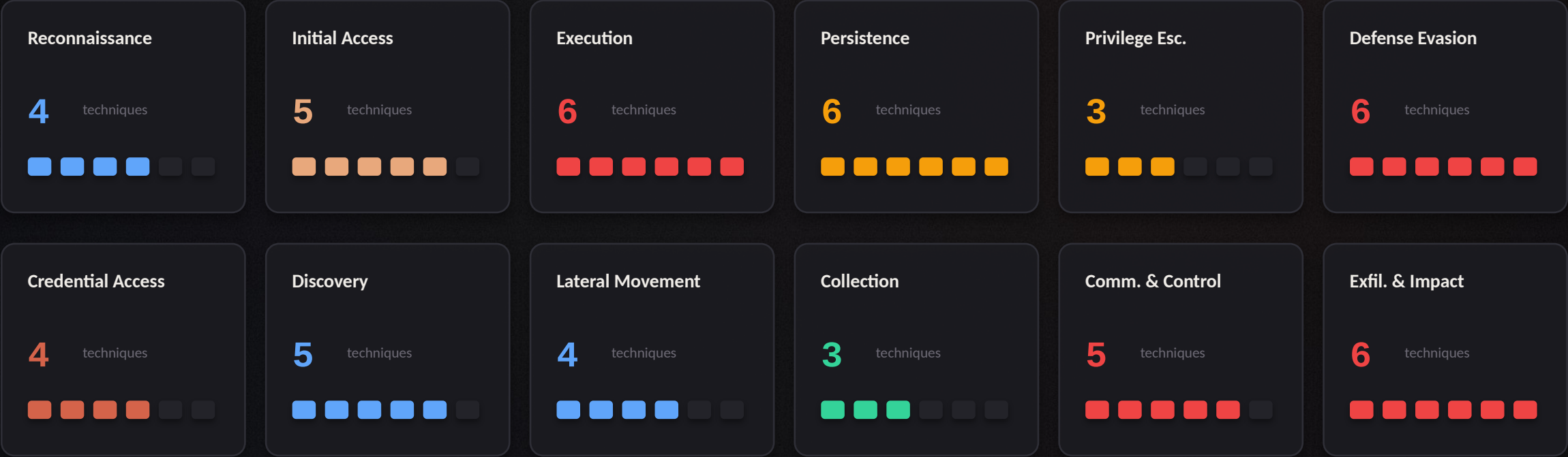
The platform never names an APT. Nothing a honeypot observes can support that claim, so the claim is not made.

Measured signals support a claim about **method**. They do not support a claim about **identity**.



Mapped to MITRE ATT&CK, tactic by tactic

54 techniques are referenced across the rule set, scenarios and analysis engines.

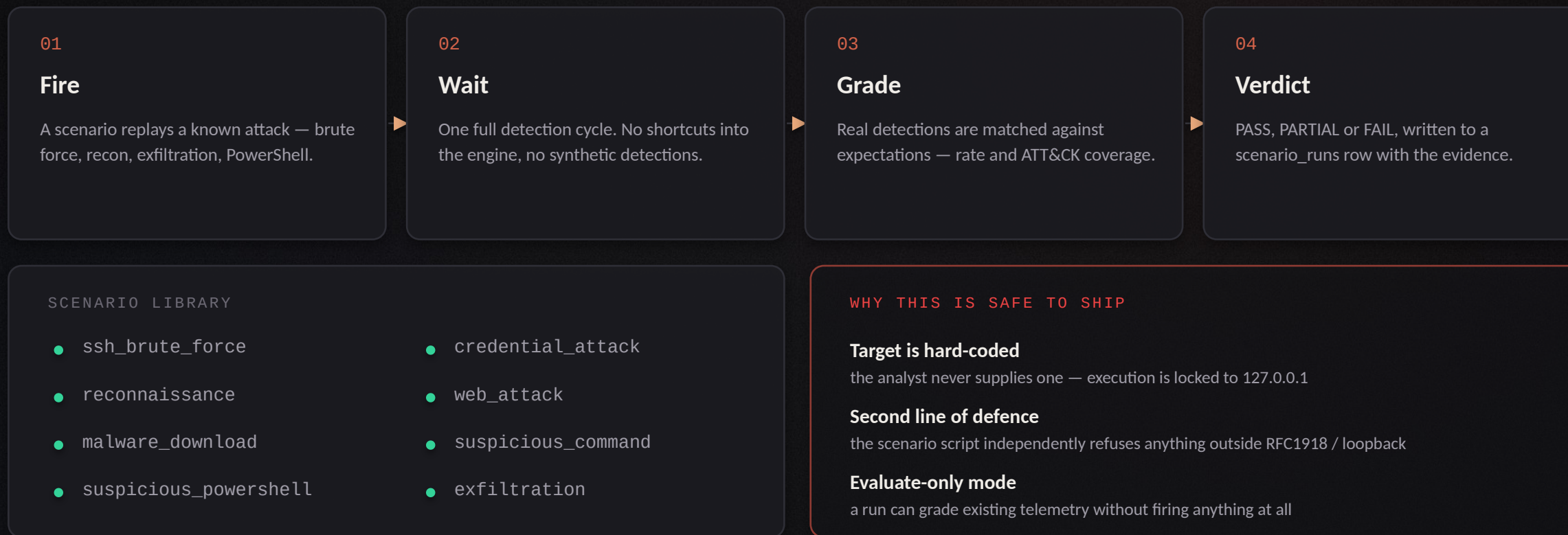


Coverage is claimed only where a rule, a scenario or an analysis engine actually references the technique — the matrix reflects the code, not an aspiration.

T1110 · T1078 · T1059 · T1105
T1046 · T1190 · T1486 · T1567 · ...

The platform grades its own detection

Eight controlled scenarios are fired at the honeypots; one detection cycle later, what the real pipeline produced is graded against what the scenario expected.



A detection pipeline that has never been tested against a known attack **is an untested pipeline**.

An analyst shell that feeds the same pipeline

A disposable Linux sandbox with no route out. Every command typed and every outbound connection attempted becomes an ordinary telemetry event.

analysis-lab · session a7f3

```
analyst@sandbox:~$ uname -a
```

```
Linux sandbox 6.1.0 x86_64 GNU/Linux
```

```
analyst@sandbox:~$ wget http://185...42/x.sh
```

```
connect: Network is unreachable
```

→ captured as event `honeypot_type=AnalysisShell`

→ matched `st-exec-004` stager download

→ technique `T1105` · graph node added

CONTAINER HARDENING — ENFORCED IN CODE

- internal network no egress whatsoever
- no Docker socket the sandbox cannot reach the daemon
- no host mounts nothing of the host is visible
- cap_drop: ALL plus no-new-privileges, non-root user
- 512 MB · 1 CPU · 128 PIDs hard resource ceilings
- hard TTL + idle reap one live sandbox per user, then reclaimed

Validated by `container_manager.validate_analysis_run` before any container starts.

Sandbox events are tagged `honeypot_type="AnalysisShell"` and `source_ip="analyst-shell:<email>"`, so analyst activity is never mistaken for attacker telemetry — while still exercising the real detection engine, behaviour profiler and ATT&CK mapping end to end.

Three analysis engines on captured artefacts



Binary analysis

static parsing

PE / ELF headers, imports, sections, entropy

YARA

signature matching over the sample

ClamAV

an independent second opinion

secret detector

30+ hardcoded-credential patterns

CAPE (optional)

real dynamic detonation when configured



APK inspector

MobSF engine

backing the Android analysis path

manifest review

permissions, exported components, intents

certificate

signing metadata extracted from the package

static findings

merged into the same evidence model

same custody rules

samples stay out of the web root



URL scanner

live DNS + SSL

resolution and certificate inspection

HTTP probe

status, redirect chain, response headers

entropy check

algorithmically generated domain names

homograph check

look-alike Unicode substitution

WHOIS + geo

real registration and IP geolocation

THE DESIGN PRINCIPLE THAT GOVERNS ALL THREE

Where a capability needs an external service that is not configured — CAPE, VirusTotal, SMTP — the interface says “not configured”. It never renders a plausible-looking result. A number on screen is a number from a query.

SOC 2 readiness, assessed from the running system

49 Trust Services Criteria mapped to 25 collectors that query live data.

49 CRITERIA · SIX FAMILIES

CC1-CC9	common criteria		33
A1	availability		3
C1	confidentiality		2
PI1	processing integrity		3
P1-P8	privacy		8

HOW A CONTROL IS SCORED

met

evidence satisfies the criterion

partial

evidence exists but is incomplete

gap

the evidence contradicts the criterion

manual

cannot be judged from system data — never auto-passed

25 EVIDENCE COLLECTORS — WHAT THEY QUERY

org_roles · rbac · logical_access

who holds which role, and what it permits

user_lifecycle · admin_activity

account creation, change and removal records

change_mgmt · control_testing

configuration change and scenario-run history

monitoring_pipeline · detection_controls

collector throughput and engine statistics

incident_eval · incident_response · recovery

incident counts, MTTR and closure records

boundary · data_transmission

network isolation and transport configuration

malware_controls · vuln_detection

scanner status and analysis coverage

pipeline_integrity · output_integrity · storage_integrity

row counts and evidence-hash verification

data_classification · retention · pii_collection

what is stored, for how long, and why

capacity · availability · risk_process

resource headroom and open-risk posture

Declared plainly in the product: this is an internal readiness self-assessment, not a SOC 2 examination — a real attestation requires an independent licensed CPA firm.

Eight reports, each one provable

Executive summary
dashboard stats, detections, incidents

Geographic threat intel
events joined to IP geolocation

Incident report
detections, timeline, evidence, analyst activity

DFIR / forensic
sessions, command history, behaviour analysis

Captured credentials
parsed login payloads + issuance audit trail

Detection validation
scenario runs graded against real detections

Malware analysis
static + YARA + ClamAV + secret findings

SOC 2 readiness
49 controls scored from live evidence

PROVENANCE BLOCK — ON EVERY COVER

generated_by	the authenticated operator who ran it
generated_at	UTC, alongside the operator's local time
data_window	the exact interval the report covers
source_systems	which subsystems were queried
row_counts	how many records each query returned
document_sha256	hash of the rendered PDF itself

Rendered with WeasyPrint + Jinja2 · stored server-side · authenticated download only

A reader can take any figure in a Shadow Trust report, look at the provenance block, and see which system answered it, over what window, and how many rows were behind it. That is the difference between a report and a screenshot.

Implementation

Five languages, one relational core, twelve containers.

Browser

40 static pages · vanilla JS · Chart.js · Server-Sent Events

nginx

serves the dashboard and the public site — never the evidence directories

FastAPI backend · Python 3.11

152 routes across 31 endpoint modules · async SQLAlchemy · JWT + RBAC

Engines

detection · correlation · session · timeline · evidence · compliance · reporting

MariaDB 11

31 models · aiomysql async driver · phpMyAdmin for inspection

LANGUAGE CHOICES, AND WHY

Python 3.11

async FastAPI, plus the ecosystem the analysis engines need — yara-python, pefile, networkx, WeasyPrint.

SQL · SQLAlchemy

31 relational models with real constraints; the content hash as a primary key is a schema decision, not application logic.

YAML

detection rules and attack scenarios live as data, so they are reviewable in a diff and reloadable without a deploy.

JavaScript · HTML · CSS

no build step, no framework — the dashboard is served as static files and reads one SSE stream.

Docker Compose

579 lines describing 14 service definitions across four networks — including the two that never bridge.

Local-first by default: **docker compose up** brings up the whole platform with no cloud account. AWS mode is optional.

What is actually tested

133 tests across 16 suites — run with `make test` against a live database container.

test_collector_persistence	cursors survive a mid-cycle crash	test_local_telemetry	three sensor formats normalise to one schema
test_detection_rules	rule parsing, thresholds, grouping	test_detection_engine	correlation, incident creation, idempotency
test_detection_validation	scenario grading and target lock-down	test_timeline_and_evidence	ordering and chain-of-custody integrity
test_malware_isolation	samples are unreachable by any static path	test_container_manager	sandbox policy is enforced before start
test_analysis_shell	sandbox events reach the real pipeline	test_lab_lifecycle	provisioning, TTL and reclamation
test_docker_provider	local provider behaviour	test_provider_factory	local / AWS provider selection
test_guacamole_integration	lab desktop streaming path	test_yara_scanner	signature matching correctness
test_health_hardening	the health page cannot leak when disabled	conftest	fixtures, isolated database, deterministic clock

WHAT THE SUITE DELIBERATELY PROVES

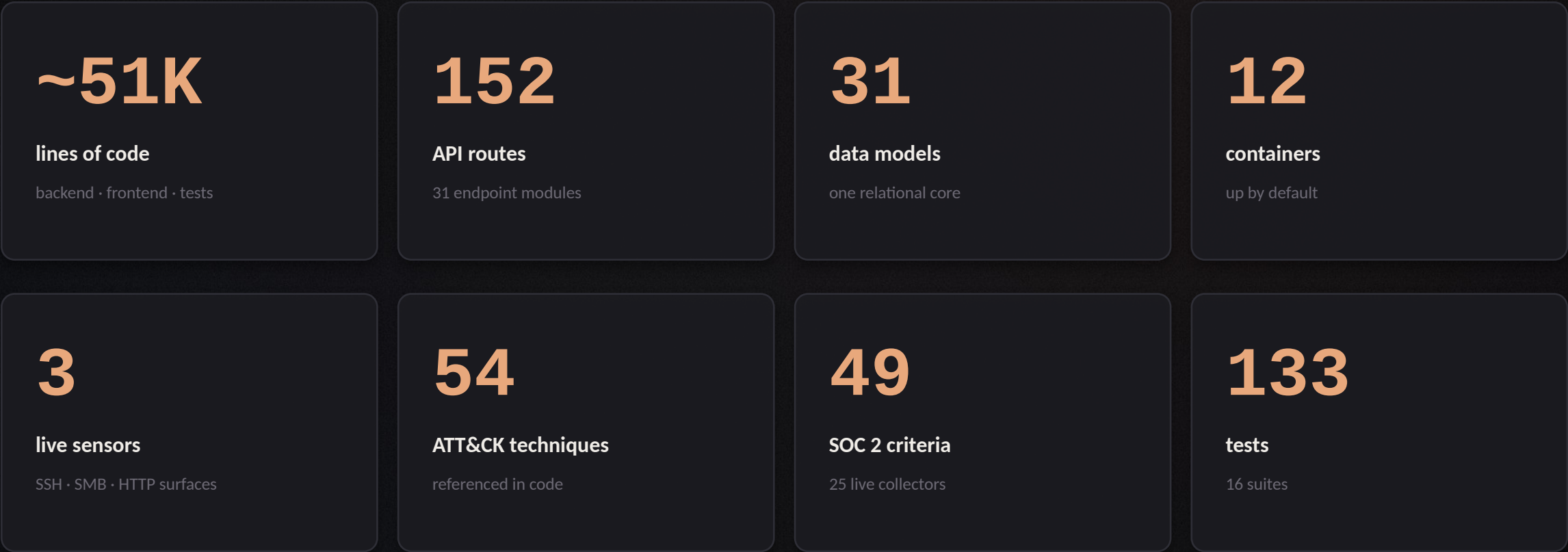
The security properties — isolation, custody, policy enforcement — are asserted in code, not just documented in a README.

KNOWN LIMITS, STATED

No load testing at production scale; no third-party penetration test; the SOC 2 assessment is self-reported readiness only.

By the numbers

Measured against the repository — these exist to show the scope, not to impress.



Eight report types, **six detection rules**, eight attack scenarios — and every figure above traces to a file in the repository.

What was built, and where it goes

CONCLUSION

Shadow Trust carries a single event from a live honeypot to a graded incident, an ATT&CK mapping, a chain-of-custody record and a scored compliance control — on one machine, with the reasoning preserved at every hop and no paid service in the path.

- Detection is explainable — every finding states why it fired.
- Evidence is verifiable — every artefact carries its own hash.
- Claims are testable — the platform grades its own detection.

FUTURE SCOPE

- | | |
|-------|---|
| NEXT | Sigma rule import at scale · alert delivery to Slack and email · detection-rule authoring in the UI |
| SOON | Multi-node honeynet federation · richer IOC enrichment feeds · retention and archival policy |
| LATER | Automated containment actions · analyst workflow metrics · a published, citable telemetry dataset |

The honeynet is not the deliverable. The evidence trail is.